AWS COMMUNITY DAY PERÚ 2026

Anatomía de un Ataque en AWS
De la Intrusión a la Defensa



Terry Martin Quispe Paniagua

SecOps - FinOps - CloudOps - DevOps

TRACK	SALA	HORA
Security	A303	4:35 pm



SOBRE MÍ

Terry Martin Quispe Paniagua

Cloud & Technical Lead

- Cloud Security · FinOps · DevOps
- Diseño y operación de arquitecturas cloud.
- Autor de contenido técnico sobre AWS, DevOps, FinOps y Security.
- Cloud & DevOps de día. Rompo mis propios labs para entender cómo defenderlos o cómo arreglarlos.

in/terry-martin-quispe-paniagua · dev.to/terry_cloud

AGENDA

Lo que veremos hoy

Demo como hilo conductor.
Preguntas antes de cada salto.

DEMO → DEFENSA

01 **Seguir una cadena real, paso a paso**

02 **Observar cómo cambia la identidad**

03 **Mapear la cadena a MITRE ATT&CK**

04 **Cortar el camino: prevención + detección**

05 **Contener credenciales y sesiones**

01

Anatomía del ataque

Una cadena plausible: cada comando responde una pregunta que nació del paso anterior.



ANTES DE EMPEZAR

Somos Blue Team: entender para defender

Usamos esta cadena como un recurso didáctico para reconocer señales, reducir exposición y responder mejor.



LAB CONTROLADO

Cuenta propia y aislada



OBJETIVO DEFENSIVO

Entender señales y controles



SOLO CON AUTORIZACIÓN

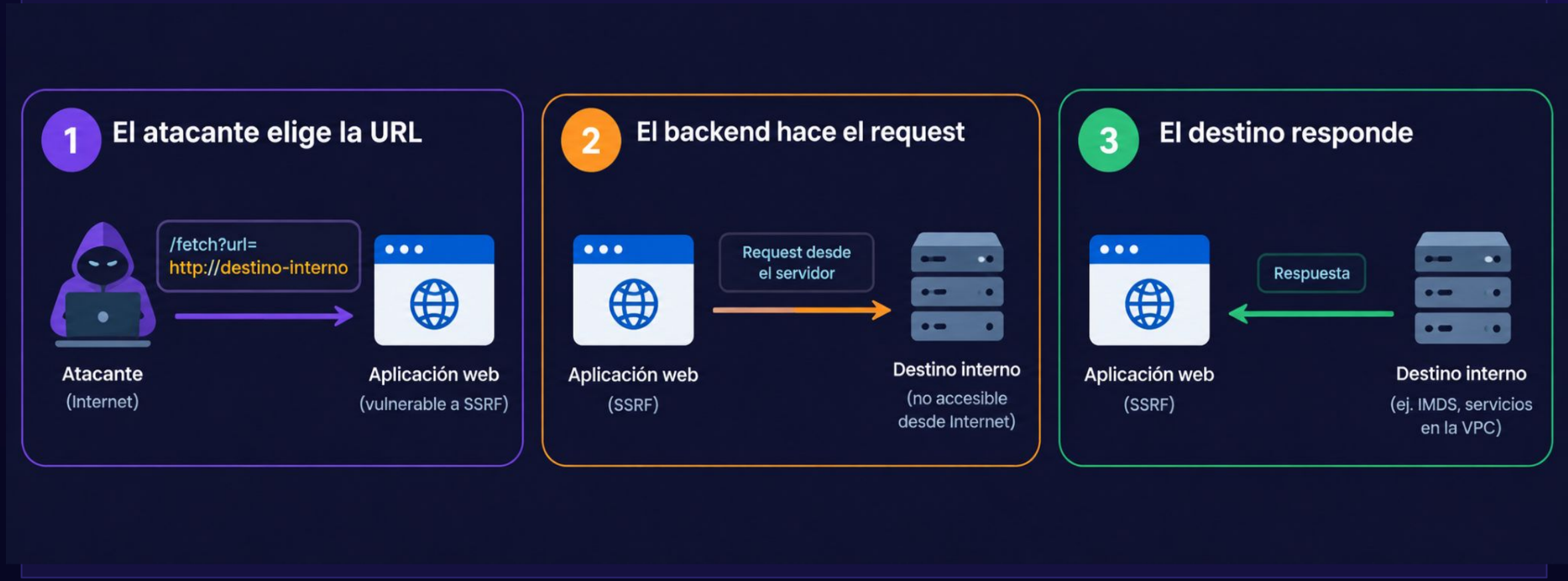
Nunca en entornos ajenos



No enseñamos a atacar AWS: entendemos el comportamiento para poder defenderlo.

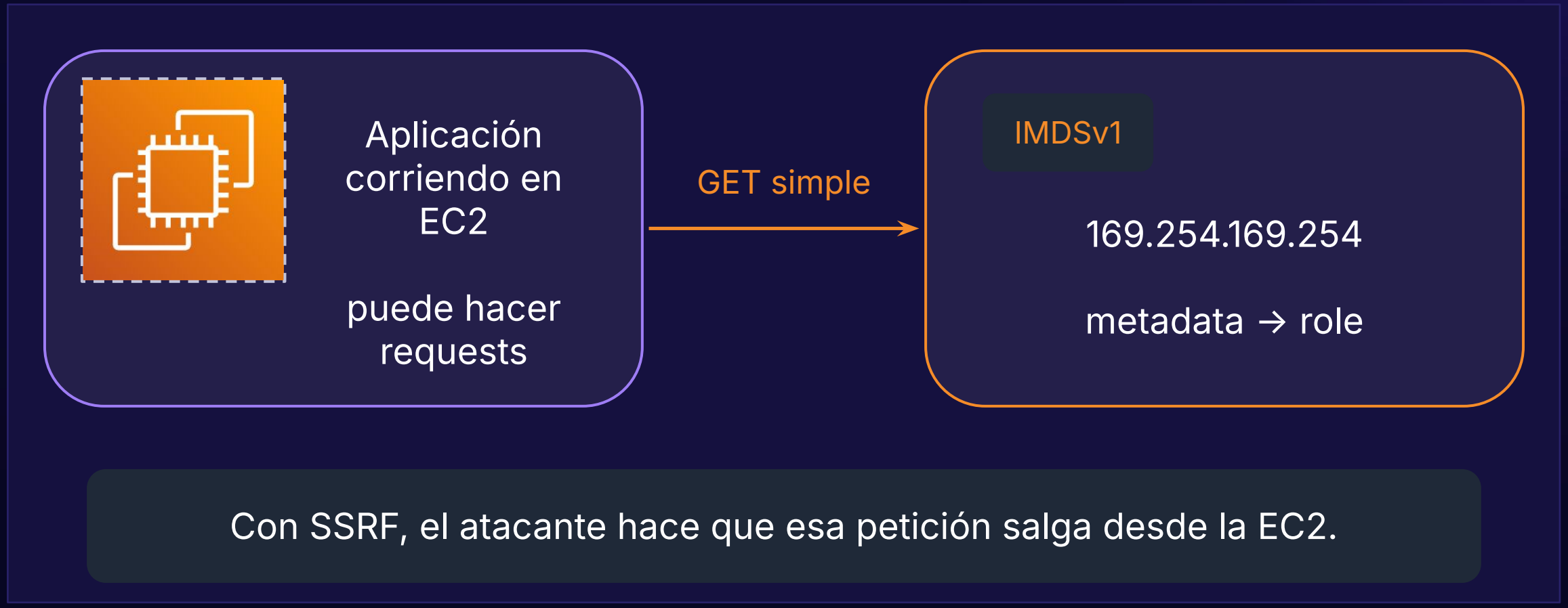
SSRF: cuando el servidor hace la petición por ti

Tú controlas el destino. La aplicación realiza el request desde su propia red.



IMDSv1: la EC2 puede consultar su propia metadata

No está publicado en Internet. El request ocurre desde dentro de la instancia.



1 · ¿La aplicación hace requests por mí?

T1190 · Initial Access

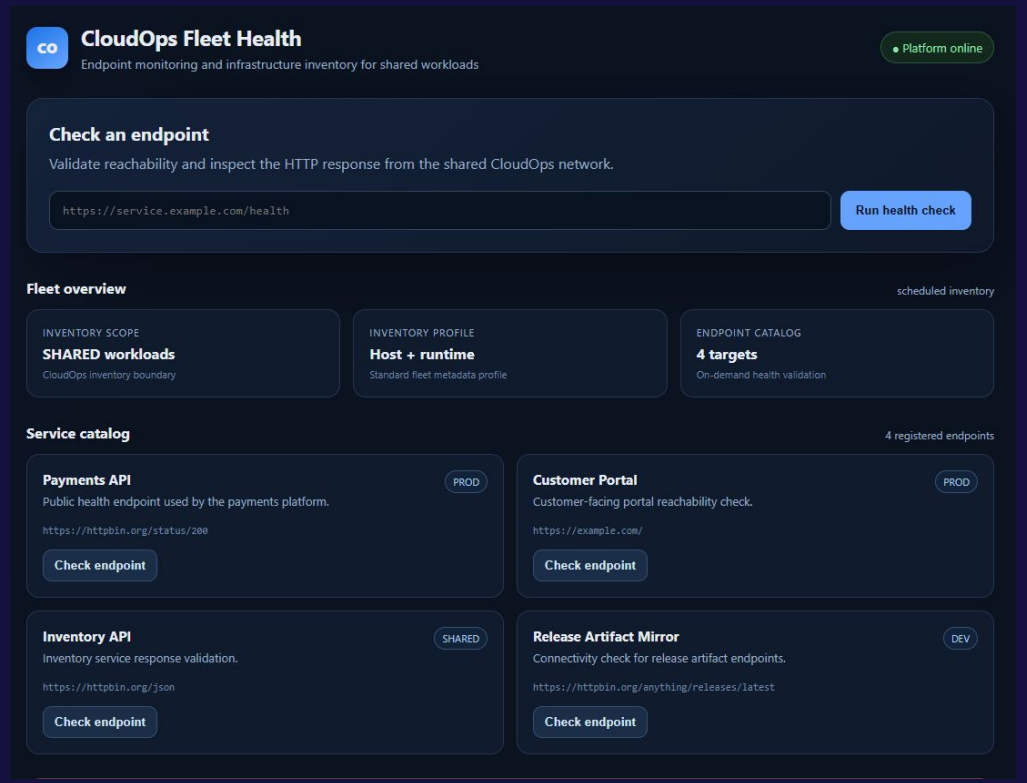
La siguiente acción nace de la evidencia anterior; no de conocimiento previo del entorno.

LO QUE VEO

CloudOps Fleet Health recibe una URL y devuelve el resultado del health check.

LO QUE ME PREGUNTO

¿El backend hace realmente el request? ¿Puede alcanzar destinos que yo no alcanzo desde Internet?



APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

2 · ¿Puedo alcanzar metadata?

T1552.005 · Credential Access

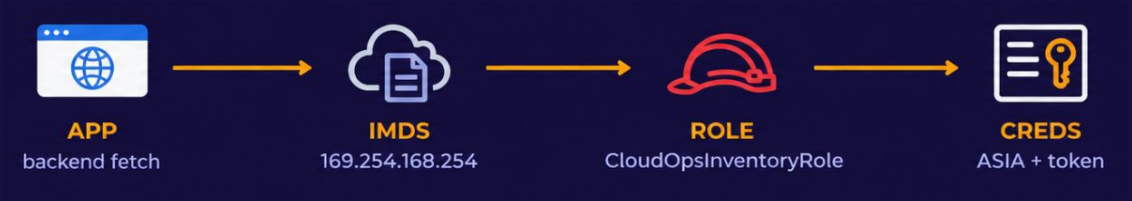
La siguiente acción nace de la evidencia anterior; no de conocimiento previo del entorno.

LO QUE VEO

El backend puede consultar una URL arbitraria desde la EC2.

LO QUE ME PREGUNTO

¿Puede llegar a 169.254.169.254? Si IMDSv1 está habilitado, ¿qué role tiene la instancia?



SSRF hace que la EC2 consulte metadata desde dentro del workload.

IMDSv1: una petición GET simple es suficiente en este laboratorio.

3 · ¿Quién soy y en qué cuenta estoy?

T1078.004 · Valid Accounts

La siguiente acción nace de la evidencia anterior; no de conocimiento previo del entorno.

LO QUE VEO

Acceso

LO QUE ME PREGUNTO

¿Qué identidad efectiva tengo? ¿Hay contexto que delate que la credencial salió del workload?

TERMINAL

aws sts get-caller-identity



APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

Time to DEMO

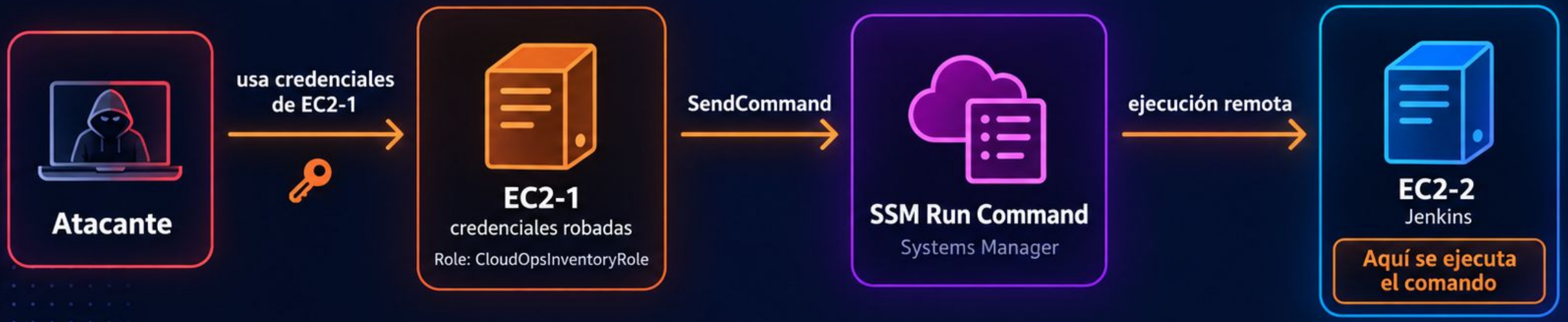
From a simple web application to **real** AWS access.



APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

DEMO · PIVOT CON SSM

SSM Run Command: quién envía y dónde se ejecuta



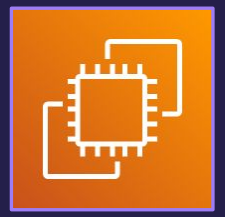
La API se invoca con la identidad de EC2-1, pero el comando corre dentro de EC2-2.

Por eso CloudTrail muestra quién envió la orden, no el contenido completo del shell en pantalla.

DEFENSA · PUNTO DE CORTE 01

Corta la cadena antes de que existan credenciales

Corta SSRF → IMDS antes de que salga una credencial AWS.



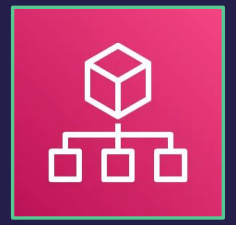
EC2

IMDSv2 obligatorio



IAM

Least privilege



ORGANIZATIONS

Deny RoleDelivery < 2.0

MOMENTO DE LA DEMO

APP · **IMDS** · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

PUNTO DE CORTE · ENTRADA

IMDSv2 obligatorio: por qué ya no funciona

La aplicación sí llega a 169.254.169.254, pero la metadata ya no se entrega sin token.

1. La app hace la consulta
La SSRF intenta leer /latest/meta-data/

2. IMDSv2 exige un token
La instancia tiene HttpTokens = required

3. Sin token, IMDS responde 401
No entrega credenciales ni metadata útil

Health check result • FAILED
http://169.254.169.254/latest/meta-data/

LATENCY	TARGET HOST
6 ms	169.254.169.254

ERROR DETAILS

```
HTTP 401: Unauthorized
```

IMDSv2 requiere un token de sesión obtenido previamente con un método PUT. Un GET directo al endpoint de metadata ya no basta.

SSRF → IMDSv2 requerido → 401 Unauthorized

Resultado: la cadena se corta en la entrada y la SSRF no obtiene credenciales del role.

DEFENSA · DETECCIÓN 02

La credencial cuenta dónde nació y dónde se usa

Si la credencial sale de contexto, detecta dónde nació y desde dónde se usa.



CLOUDTRAIL

Contexto de credencial



GUARDDUTY

Credential exfiltration



SECURITY HUB

Centraliza findings

MOMENTO DE LA DEMO

APP · IMDS · **CLOUDOPS** · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

DEFENSA · CORTE 02

IDENTIDAD · least privilege

La identidad no debe abrir el siguiente salto

CloudOpsInventoryRole debe quedarse en *inventario*, no en ejecución remota.



- Solo lectura / inventario
- Quita permisos no usados
- Valida con IAM Access Analyzer

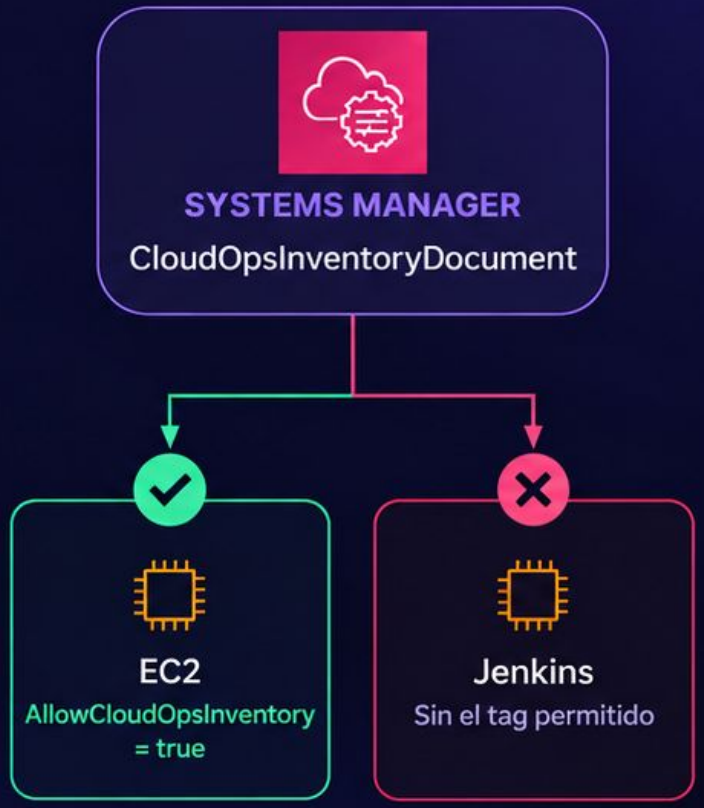
APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

DEFENSA · PUNTO DE CORTE 03

SSM: inventario solo en instancias permitidas

IAM policy (ssm:SendCommand)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ssm:SendCommand",
      "Resource": "arn:aws:ssm:us-east-1:123456789012:document/CloudOpsInventoryDocument"
    },
    {
      "Effect": "Allow",
      "Action": "ssm:SendCommand",
      "Resource": "arn:aws:ec2:us-east-1:123456789012:instance/*",
      "Condition": {
        "StringEquals": {
          "ssm:resourceTag/AllowCloudOpsInventory": "true"
        }
      }
    }
  ]
}
```



MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · **JENKINS** · JENKINS ROLE · TFSTATE · PROD ROLE · PERSIST

DEFENSA · IDENTIDAD 04

Jenkins no debe ampliar el alcance de CloudOps

El role del workload define cuánto puede crecer el blast radius.



IAM

Reduce permisos



S3

Aísla buckets sensibles



CLOUDTRAIL

Correlaciona identidad

MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · JENKINS · **JENKINS ROLE** · TFSTATE · PROD ROLE · PERSIST

DEFENSA · DATOS 05

Terraform state: trátalo como un mapa sensible

El tfstate revela arquitectura aunque no contenga secretos.



S3

Bucket dedicado



IAM

Acceso mínimo



CLOUDTRAIL

Data Events en tfstate

MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · **TFSTATE** · PROD ROLE · PERSIST

DEFENSA · DATOS 04

tfstate: acceso controlado por bucket policy y role dedicado

Jenkins sigue desplegando, pero solo puede acceder al backend de Terraform que necesita.



</> Bucket policy · ejemplo

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowTfstatePrefixList",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456789012:role/TerraformBackendRole"
      },
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::orgsec-tfstate-123456789012-us-east-1"
      "Condition": {
        "StringLike": {
          "s3:prefix": "envs/prod/*"
        }
      }
    },
    {
      "Sid": "AllowTfstateObjects",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456789012:role/TerraformBackendRole"
      "Action": [
        "s3:GetObject",
        "s3:PutObject",
        "s3:DeleteObject"
      ],
      "Resource": "arn:aws:s3:::orgsec-tfstate-123456789012-us-east-1/envs/prod/*"
    }
}
```

Controles clave

IAM least privilege

Evita AdministratorAccess en CI/CD. Jenkins asume un role dedicado con permisos mínimos.

Bucket policy específica

Autoriza solo el bucket, prefijo y acciones S3 que TerraformBackendRole realmente necesita.

RCP (defensa en profundidad)

Un Deny organizacional sobre S3 puede reforzar límites incluso frente a identidades con permisos amplios.

Resultado: Jenkins conserva el backend que necesita; el acceso al tfstate se segmenta por role, bucket/prefijo y RCP.

DEFENSA · TRUST 06

Cross-account: confianza explícita y mínima

La trust policy es una frontera de seguridad entre cuentas.



IAM

Trust mínima



ACCESS ANALYZER

Detecta acceso externo



Organizations

Restringe acceso externo

MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · **PROD ROLE** · PERSIST

DEFENSA · TRUST 06

Cross-account: trust policy explícita y mínima

No confíes en toda una cuenta si solo un *rol* específico debe asumir acceso.

MAL EJEMPLO

Confía en toda la cuenta externa (completo root).

```
{
   "Effect": "Allow",
   "Principal": {
     "AWS": "arn:aws:iam::123456789012:root"
   },
   "Action": "sts:AssumeRole"
}
```

Demasiado amplio

BUEN EJEMPLO

Confía solo en un rol específico y usa ExternalId.

```
{
   "Effect": "Allow",
   "Principal": {
      "AWS": "arn:aws:iam::123456789012:role/
              TerraformBackendRole"
   },
   "Action": "sts:AssumeRole",
   "Condition": {
      "StringEquals": {
        "sts:ExternalId": "tf-backend-prod"
      }
   }
}
```

Rol específico + ExternalId

CONTROLES

Detecta, limita y monitorea el acceso cross-account.

IAM

Trust policy mínima

ACCESS ANALYZER

Detecta acceso externo

CLOUDTRAIL

Monitorea AssumeRole

La frontera entre cuentas vive en la trust policy. Si la defines mal, el salto cross-account sigue abierto.

MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · **PROD ROLE** · PERSIST

DEFENSA · CONTENCIÓN 07

Si algo pasó: corta credenciales y sesiones

Cerrar la entrada no invalida credenciales ni sesiones ya emitidas.



IAM

Desactiva la key



IAM · ROLE

Revoca sesiones



CLOUDTRAIL

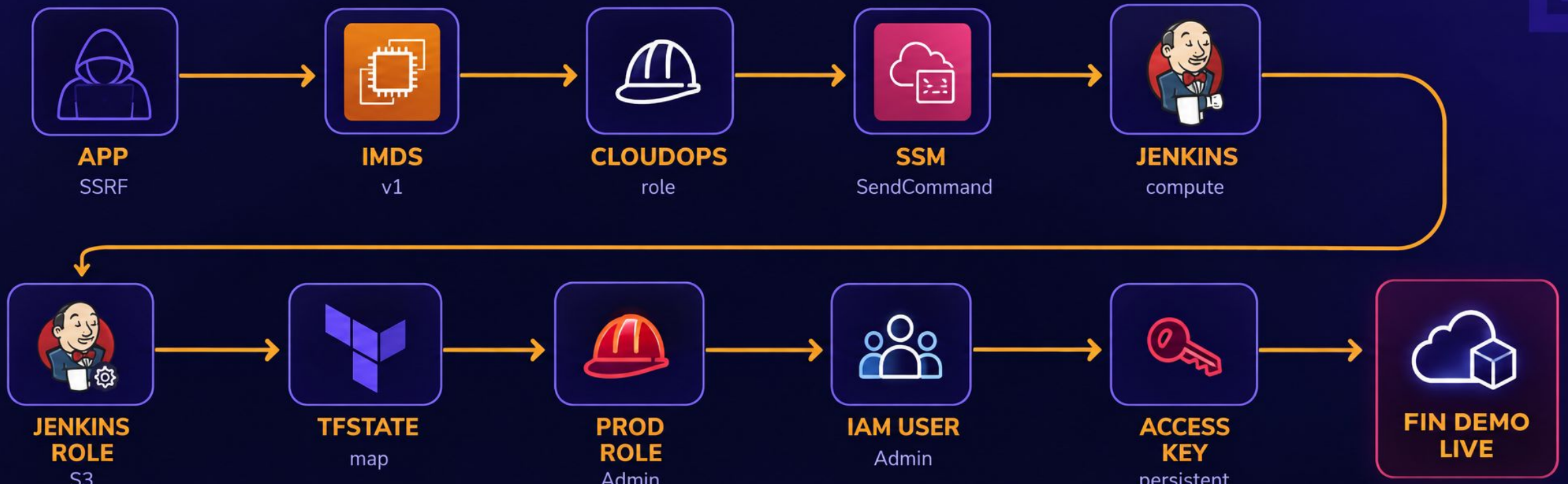
Busca actividad derivada

MOMENTO DE LA DEMO

APP · IMDS · CLOUDOPS · JENKINS · JENKINS ROLE · TFSTATE · PROD ROLE · **PERSIST**

Demo completa: la cadena ya se sostiene sola

Doce decisiones pequeñas terminaron en una credencial administrativa independiente.



La charla no depende de IMDSv1

PUNTO DE ENTRADA DEL LAB



SSRF → IMDSv1 → STS

La credencial temporal sale del contexto de la EC2.

OTRA ENTRADA POSIBLE



Access key expuesta



Desde una identidad AWS válida, la cadena converge.

POST-DEMO

¿Qué pasa si AWS detecta una credencial comprometida?

Detección, quarantine y respuesta operativa.



DETECTAR

LIMITAR

RESPONDER

POST-DEMO

Si AWS encuentra una access key expuesta



DETECCIÓN

Repositorios públicos
+ señales de uso irregular

Exposed · Suspected · Potentially compromised



AWS RESPONSE

AWS puede limitar temporalmente la creación de algunos recursos.



IMPORTANTE

Eso NO asegura la cuenta.

La detección es una señal de incidente, no la remediación.

POST-DEMO

AWS puede aplicar una quarantine policy

Ejemplo: AWSCompromisedKeyQuarantineV3

QUÉ HACE



Deny sobre acciones sensibles

IAM • EC2 • S3 • KMS

QUÉ NO HACE



No recupera la cuenta

No investiga por ti

No reemplaza la respuesta del equipo



Quarantine limita el daño; el incidente sigue abierto.

Sigue el análisis, la contención y el soporte.

Puedes automatizar la contención

GuardDuty publica findings en EventBridge; desde ahí puedes disparar una respuesta controlada.



CONTENCIÓN REVERSIBLE

Preserva el principal y su configuración para investigar.

Después de contener: investiga el blast radius



1 · IDENTIDAD

User · role · session

AccessKey involucrada



2 · ACTIVIDAD

APIs · regiones

source IP · userAgent



3 · DERIVADOS

AssumeRole · nuevas keys

roles · recursos



4 · IMPACTO

Datos accedidos

EC2 / Spot · billing



La alerta identifica una señal; tu investigación determina el alcance.

Tres ideas para llevarse

1

La entrada cambia

La identidad válida es el punto común.

IMDSv1 fue el vehículo del lab, no la tesis.

2

Detección ≠ contención

GuardDuty y AWS Support pueden darte señales y límites.

3

La recuperación es tuya

Contain · hunt · recover.

La recuperación sigue siendo tu responsabilidad.



¿Preguntas?

Hablemos de la cadena, detecciones, contención o cómo reproducir el laboratorio.

AWS COMMUNITY DAY PERÚ 2026

¡Gracias!

Terry Martin Quispe Paniagua

Cloud & Technical Lead

ESCANEA Y CONECTEMOS